

Scope of Work Sprint2/3 Plan

CSCE798

Sprint Status

- Sprint0 -> Understanding the Stats 542 App and what we built in the spring. (Complete)
 - Sprint1 – Upgrading the original Application to a More Modern Standard and Higher Security (Complete – G2 Port to Gen3 Azure)
-
- Sprint2 – Delivering Standard Product Processes, App, And Most of the Cipher, Draft of Architectural Papers needed for Production X5. (Set for 10/16/2026)
 - Sprint3 – Final Draft of Thesis on PGP Privacy For Rest Fabrics inclusive of Audit & Traffic Tools. (TBD)

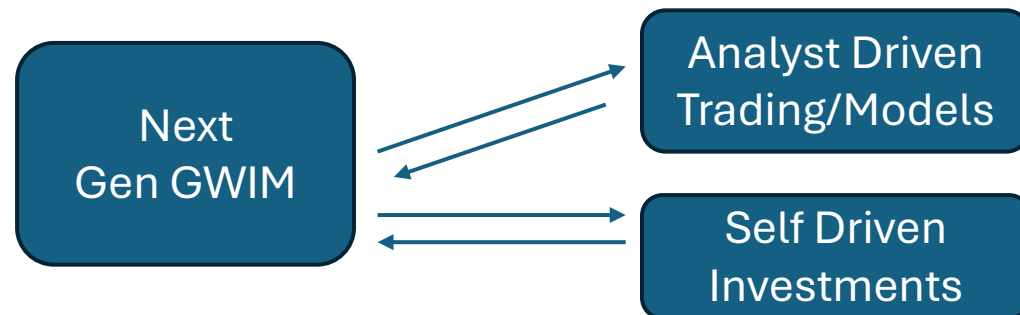
Case Study

Next Generation GWIM Tools Deployment

09/23/2026

We Are Cocky Financial... A Virtual Company

- Our Executive Linda has asked us to build a new app...which manages customer trades in a controlled manner following a financial proposal from a licensed security analyst. Traders check the analysts orders for accuracy but do not overrule the analyst.
- Linda has a boss Bob who would like to have a product which reaches smaller investors who could self trade.
- Bob and Linda envision a tool which could do both at the same time... IE two modes of operation rather than separate tools which are common at ML, Chase, and other competitors.
- Competitive Research By Cocky Investments VPs.... Fidelity uses the same tool for both sets of customers (High, and Low). Charles Schwab also operates with a single tool for both sets of customers. ML, Chase, and Wells do not have such a tool.



Bob & Linda have problems....

- Igor is running ops....



And Natasha – IT Audit



- 1) They don't allow anything on Tiered Network Infrastructure That Doesn't Pass Audit.
- 2) DBMS Technology has to be Oracle, or MS-SQL Server (Due To Replication Requirements for DR)
- 3) Enterprise Apps have to run on secure ports.
- 4) All Apps have to have application encryption & meet FISMA & NIST standards in every category.

Other Concerns....

- Bob is a Corporate Officer and Division President. He has a fiduciary responsibility to deliver secure software which is his sole responsibility.
- Bob needs to increase revenue and he's not sure increasing trading volume will do so.
- Bob needs to insure that self-trading applications do not degrade Flagship operations with analyst proposals.
- Linda wants better workflow management from Analysts to Trading Operations rather than Email, and IM.
- Linda wants the new system to add a workflow management system from
 - client->analyst->trading operations.

Bob and Linda want speed....

- They want to rapid prototype an Interface which does what they want...so they can ask for money to make it into production....
- The CEO cant envision what they are saying...right now or the benefits of the new system so they need to show him a proof of concept.
- Natasha and Igor cant risk their existing businesses... and operations.....
 - They let Bob and Linda do whatever they want on their own LAN using IPV6 link local addresses....
 - But WILL not install tools into the core DCs without meeting security baselines...
- Linda & Sally quickly crank out Gen1, and Made Gen2 a bit better...but it runs on SQL lite....
 - AND ITS VERY VERY FAR AWAY FROM PRODUCTION
 - AND WOULD FAIL PRODUCT REQUIREMENTS AS IT DOESN'T TAKE PAYMENTS OR TRADE.
- They call Natasha and Igor for a list of requirements that they need to go to production, and costs to go to shared hosting in Tier.
- Natasha and Igor say “Where is your product description?” “Who is the Product Manager”, “Who is the Project Leader who can validate results?”

Linda's Response

- Sally on my team is the Product Manager and she will get you a product description in two weeks time.
- Rob is our lead accountant and he is responsible for the validation of the system we built together.
- I am the stakeholder, and I have to convince my boss I can meet both trading needs before Bob and I ask for Capital Programs from the Corporation.
- I would like to use API designs on the back-end as our execution system uses Microsoft DotNet Entity Framework and I need Microsoft Consulting to help with Exchange plugins to NYSE/NASDAQ.
- I know the TIER costs per unit, but I need a security plan of everything we have to do to get to production so I can ask Sally to track those items. She will create a subteam with you Igor and Natasha to track those as a Workstream #2, with Workstream #1 the actual application requirements. Workstream #3 will be the backoffice processing for trading orders and payments #4.
- We know this might cause you stress, but we want unemotional responses. We have corporate commitments and we just need the facts.



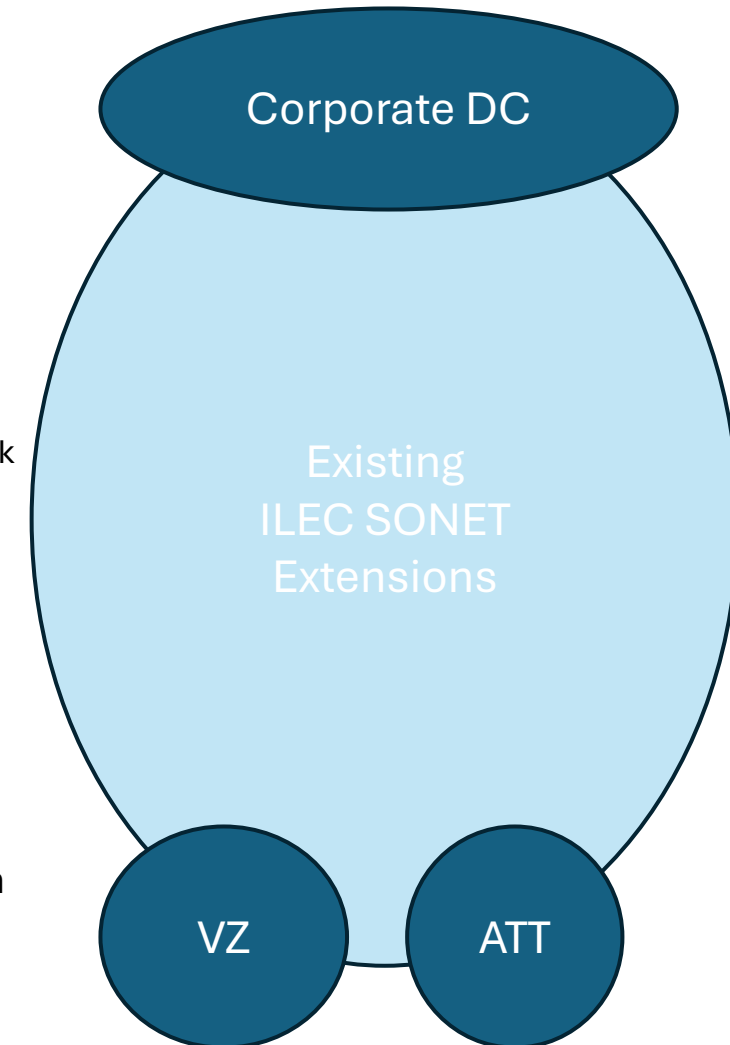
Natasha's Response

- At a minimum we have to be PCI compliant, HIPAA compliant, NIST, FISMA, and OCC Compliant and most of that is related to data in transit and on the edges. We will provide a list.
- We have an application Enterprise(9) Logging Requirement which requires a lot of additional actions in the clients which you probably never seen before. This is 9 groups -> 13 groups of Log files for audit.
- Your App has to be installed into the corporate Active Directory with users who have SSO access. This requires them to be onboarded and 2 factor authentication enabled. If you need social logins we have a process to do that but it takes more time.
- Clients, Servers and Networks have to be in line with existing standards and shared services using banded images, and have to be registered and fully managed in Operations before we can do even pilot testing. Your apps will not go on any LANS/WANS before every image is compliant.
- We have two compliant DBMS platforms, Oracle or MS-SQL in production for replication purposes to the three DC's. You cannot use MySQL or SQLite in production so don't waste time with them.
- MSSQL server does have a local product if you need flat file support so that's our recommendation if you cant put a local Oracle/MSSQL server on your local lan.
- Entity Framework has never been used at Cocky Financial we have been using Oracle OCI drivers on Enterprise Workstations, and when remote access is required, we run the same apps on Citrix VDI servers over VPN appliances. This is a new Data Architecture.
 - **We Therefore need a new API Audit Tool**
 - **We Therefore need a new API Billing Modification to Handle Usage Based API Billing.**

Igors Response....

- Datacenters, SANS, and DBMS for Shared Services are available at all production targets. We offer bare metal installations for good servers we can charge you for....
- We can extend to ILEC DC's in the same cities if its required. You can use ATT/VZ/CTL local rings to reach us in market. If you do however we have to buy SONET encryptors for each new suite we add to these extended services.
- All Architectural Standards have to be supported by a Laboratory Program.
- We have several problems:
 1. We need to understand options to Encrypt Client-Server Traffic which will require a new architecture.
 2. We need to understand how traffic flows will change when we run to REST Backoffice APIs versus thick clients to Databases directly over OCI. This will also require a new architecture.
 3. We need to build a new Audit Architecture for API Endpoints which we can track, and we need to be able to usage based bill API tools.
 4. You have identified you want to use REACT vs .ASPX pages and this means we have to review Page Level Security and Field Level Security using non-Microsoft tools.
 5. We have to add Alarm points to the new API Endpoints so we can manage them.
 6. We have to "Color" the traffic going into the new API service platforms so we can report on traffic changes and plan for network upgrades.
 7. The Simulated Order to Portfolio process WILL REQUIRE COMPLEX NESTED JSON POSTS. (CG Posts).
 8. We would like to have a Keyless Cipher System which cant be broken.
- Of course all other operational parameters are mostly covered by our bare metal solutions which are prewired with the right cross-connects, LDX panels, and minutiae you don't care about all that much.

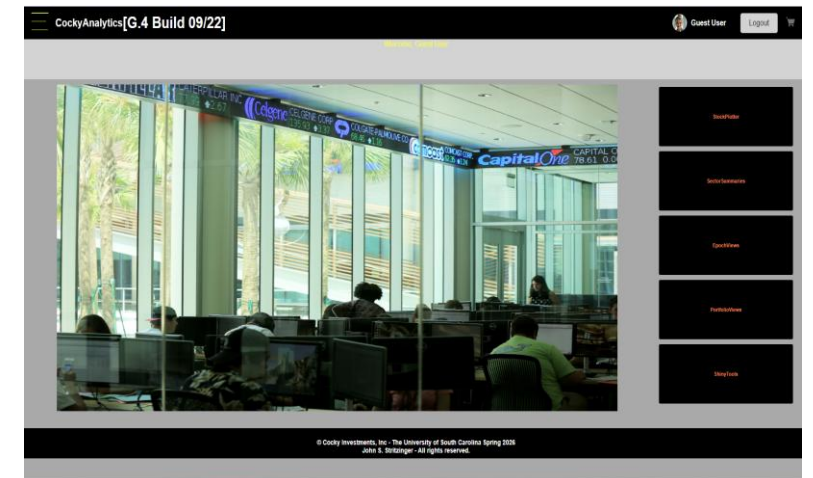
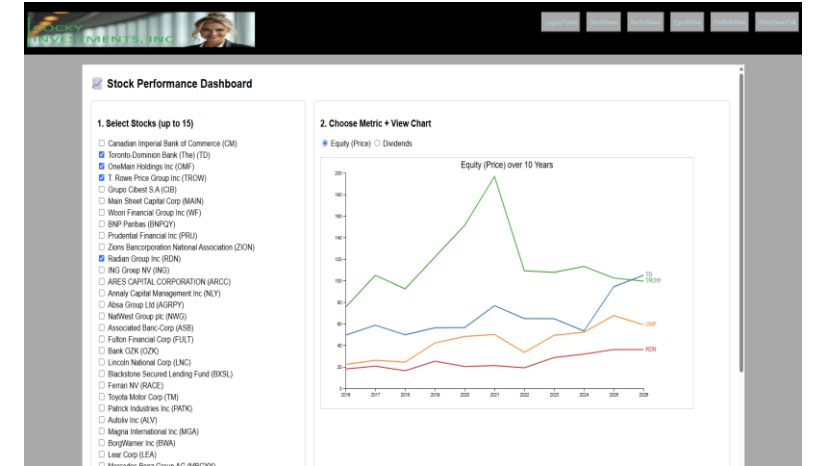
IGOR HAS OUTLINED 8 GENERAL ARCHITECTURE DOCUMENTS WHICH NEED TO BE CREATED AND DON'T EXIST TO GO TO PRODUCTION.



Lindas Review of App Status & NextGen GWIM Business Requirements

1)Gen1/Gen2

- FRONTOFFICE - UI Features
 - Missing the Ability to Take a Proposal And Prepare a Trading List Work Order.
 - Missing the Role of Trader to review work orders.
 - Missing Customer Portfolios And Simulated Executions at Market.
 - These APP requirements are modest using AI Tools to assist as the DB upgrades were done by Sprint1.
- GAPS -> Two additional Workflows
 - A Trader Needs to Be Able to Accept a work Order or send it back to the Analyst for changes with comments.
 - The completed work orders when then show for the customer to view his execution price, and total investments.
 - The good news.... Is Analysts are completely responsible for customer work orders. In other words carrying out their work isn't trivial but its within the capabilities of most business majors with a few months training OR 4 Data Scientists no problem.
- BACKOFFICE
 - The Database was upgraded for Gen3 to meet these extra requirements -> COMPLETE
 - Cocky Investments Needs A Trader Work Screen, and the Ability to accept a Plan. This would then make a complex CG Southbound Post for the workorder. (Trade Order is up to 100 securities at Market Price for simplicity) -> Simulate Purchase-> Simulate the Customer Portfolio.
 - We are discussing a Modified Trader Post in a similar form of the Bikes Reservation Posting System.



Product Cycle Requirements

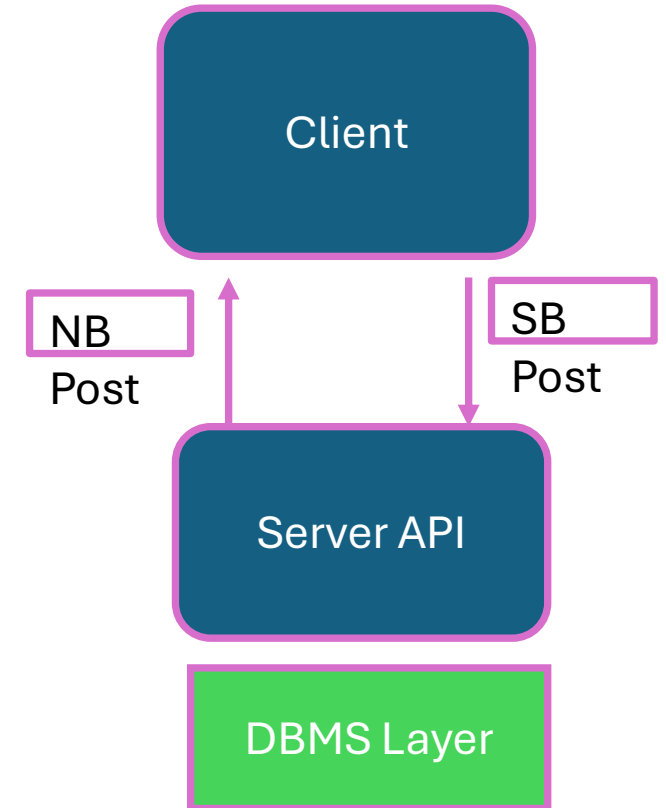
- Linda Must Generate For Natasha and Igor->
 - Business Requirements Documents
 - Straw Man on Operational Plan.
 - Sales Guide Slick Sheets
 - Pricing Model
 - Competitive Analysis
- Natasha and Igor
 - Have to Attend All Product Meetings
 - Have to Submit SOW and Cost Estimates to the Team.
 - Have to Submit an Architectural Plan for Each New Technology Component, and Reference existing ones in production where necessary.
 - Provide Min Requirements For Pilots
 - Provide Min Requirements For Security
 - Price Everything In Small Batches to Extreme Loads In Line with Other Products
- Linda Then Must Prepare a Business Case for the Executive Stakeholders.

Stakeholders Meeting (Sprint2) – Oct16

- Bob & Linda -> Present To Senior Management
 - Dr. Hitchcock is the COO. He is Bob & Linda's boss.
 - Dr. Fenner is the CTO. Igor works for Dr. Fenner.
 - Dr. Huang is Chief Legal & Compliance Officer. Natasha is his employee.
- They need to be satisfied that the product development process is followed, they have all the documentation, the app works in lower security modes. They need to understand the major engineering tasks to move to production, and to operational standards.
- RBOCs call this a MRB. It usually has to be finished to a high degree of completion to get to move to pilot.

From Bikes To Market Payloads

- CGNB Post
 - (App Setup, All Users, Roles, Products, Encryption Types, NetInfo, etc)
- CGSB Post
 - (Reservations, Financial Transactions, Credit Cards, Calendar Updates, Park Capacity Updates).
- CFNB Post
 - (User Tier & Account Restrictions, Roles, Credit Limits, SSO, NetInfo) – Similar to Parks
- CFSB Post
 - (Portfolio Orders From Analyst to Traders -> Customer Portfolio) – All New Process.
- Goal to build a CockyCipher system which can post transactions using proprietary or standard library options.
- Goal to use Transact SQL For All Trades which can be reversed.



Example CF.SB & CF.NB JSON Payloads

```
{
  "userid": "U-78429",
  "usertoken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.abc123...",
  "userfullname": "bob.smith@summitbank.com",
  "batch": {
    "batchId": "BATCH-20260923-001",
    "createdAt": "2026-09-23T16:30:00Z",
    "subBatches": [
      {
        "sector": "Technology",
        "orders": [
          {
            "ticker": "AAPL",
            "qty": 150,
            "side": "buy",
            "marketprice": 228.45
          },
          {
            "ticker": "MSFT",
            "qty": 80,
            "side": "sell",
            "marketprice": 415.20
          }
        ]
      },
      {
        "sector": "Financials",
        "orders": [
          {
            "ticker": "JPM",
            "qty": 200,
            "side": "buy",
            "marketprice": 215.30
          }
        ]
      }
    ]
  },
  {
    "sector": "Energy",
    "orders": [
      {
        "ticker": "XOM",
        "qty": 120,
        "side": "buy",
        "marketprice": 112.60
      }
    ]
  }
]
```

Field summary

Field	Description
<code>userid</code>	Unique user identifier
<code>usertoken</code>	Authentication / session token
<code>userfullname</code>	User's email or login name
<code>batch.batchId</code>	Top-level batch identifier
<code>subBatches</code>	Array of sector-based sub-batches
<code>sector</code>	Sector name for the sub-batch
<code>ticker</code>	Security ticker
<code>qty</code>	Quantity to buy or sell
<code>side</code>	"buy" or "sell"
<code>marketprice</code>	Current market price at time of order

Case Ready To Production

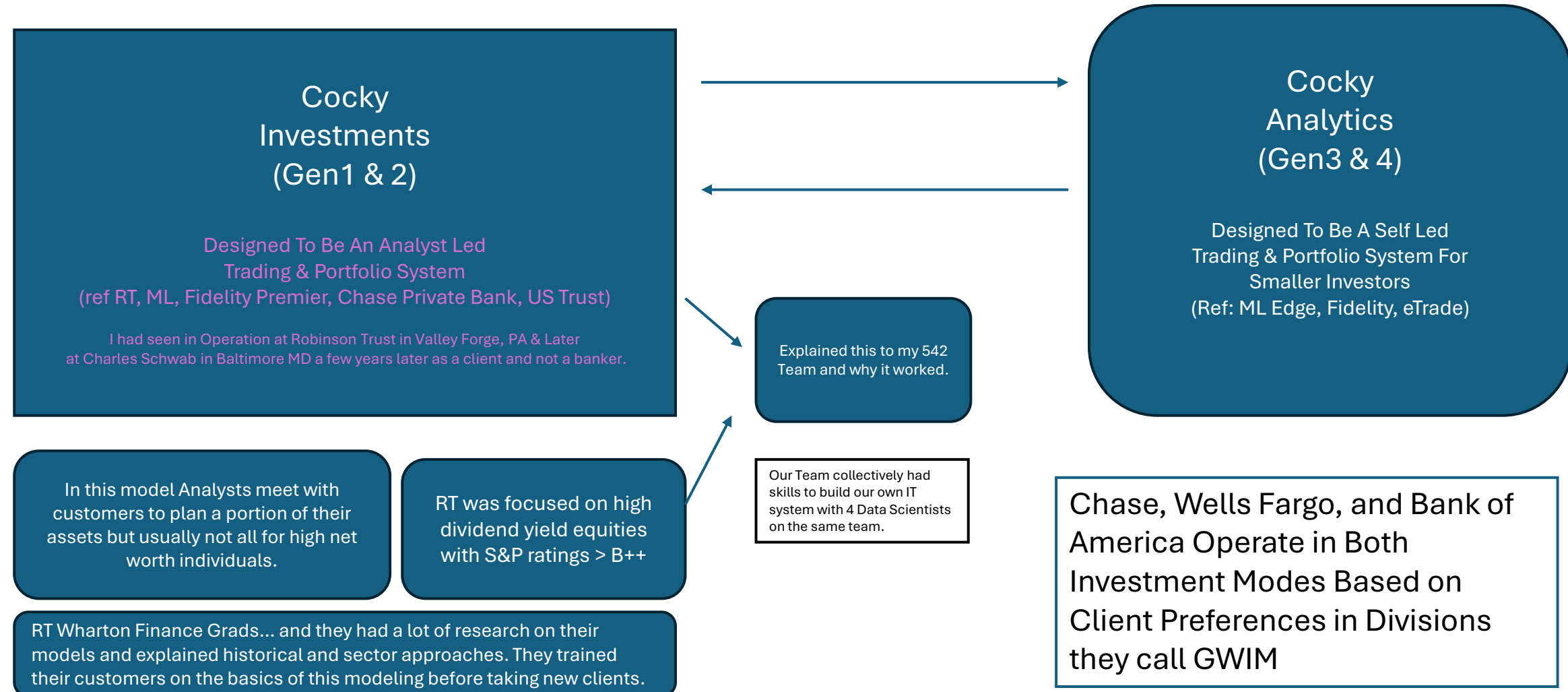
Disclaimer...And Important Point....

- An Application Could be installed in Tier for a Major Financial or Government Data Center... which does no/zero work.
 - It Requires Secure Sign On that ties to an Application Directory.
 - It Requires a Backup Plan where Code Can Be Archived.
 - It Requires Encrypted Communications, and a way to disable encryption so that problems can be isolated. (Turn the Encryptors Off For Maintenance)
 - It Requires usually a form of corporate hierarchy... understanding of role.
 - Every screen is page/form locked.
 - It must be HIPAA, PCI Compliant at a minimum store payments securely, and for Government apps meet all NIST/FISMA/DOD standards.
 - It usually also requires a known service image, an inbound TF number, and an ITSM system of some sort to meet compliance.
 - Everything else can be waived in small scale in practicality.
- In other words the STATS542 app matters less than the base operational requirements. If my application did nothing... I can still encrypt it and make it secure.
- I arrived at this after building projects in 498-1, 498-2, 242, 546, 547, 567, 587, 590, 798, 547G (10 PROJECTS)... I realized that my backoffice had similar requirements.

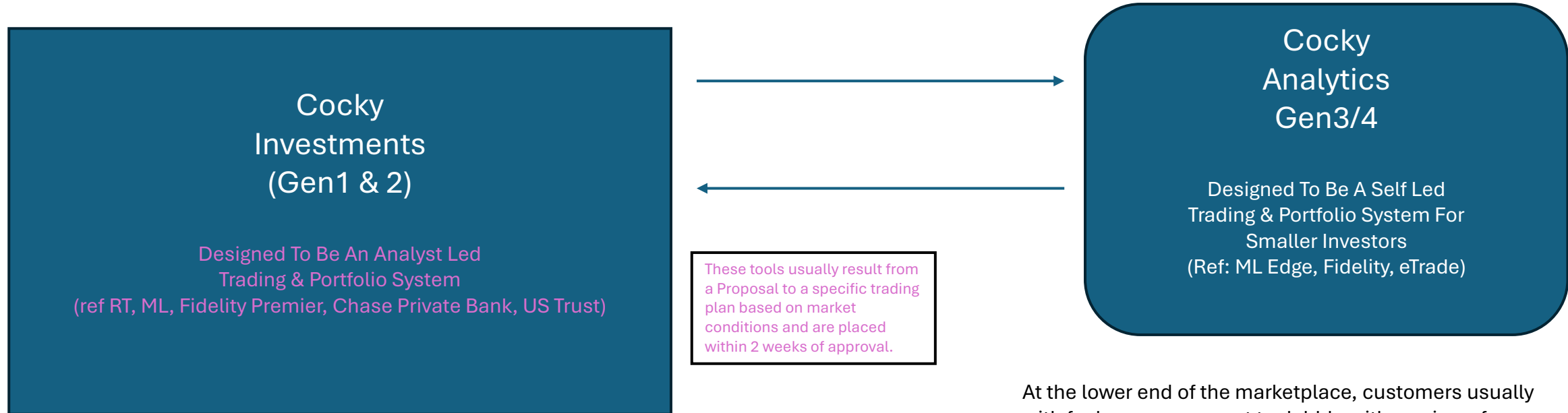
Plan of Record

- “The App”
 - Building a Financial App.
- “The Product Development Cycle For the App”
 - Taking Our App Through a PD Cycle which results in a Hosted Tiered App.
- “Security Project Management”
 - Moving Our App To Production F1000/Gov Ops would be a major undertaking to meet Audit Requirements.
- “The Papers”
 - Specific Generic Architecture Documents – Integrative Processes not necessarily new technology.
 - New Technology White Papers and Educational Documents on Things that don’t exist.
- “Committee/MRB” -> Process

First the App... then the method



To the Requirements.....



In Analyst Led Systems - Sector & Weighting Approaches are Applied to Present a Package to a customer. The package will include a Mix of Stocks vs Bonds, Mutual Funds, vs Individual Stocks, etc... They present a plan to a customer... and the customer provides feedback before they go forward. Usually customers come in with the amount they are seeking to professionally manage. This could be 50K to 10s of millions.

The key factors are the Investment Amount this is the sales pitch. Analysts have to convince customers that their models work under different economic conditions, that their education on these things is good, and that good outcomes will happen most of the time. Analysts have to pass a very difficult test called the Series7 exams which requires 10 years as an apprentice as well. **In practice it takes most 20-25 years of education to achieve their goals. Its not practical for IT people in general. The IT requirements are a mix of sectors, investment types, and cost management is the baseline. Our Team was able to achieve this using a combination of Rtools we had used, and Quantmod which has security prices.**

At the lower end of the marketplace, customers usually with far less money want to dabble with owning a few equities which they research on their own (Schwab, Fidelity, ML have reports on every stock, and Analysts who cover specific sectors).

These tools usually open this research to individuals, and they place their own orders in Real Time.

Gen4... Self Modeling?

- We cant really become ML Edge over night... as we don't have research for every stock....
- But we might be able to link stocks to Yahoo Finance or MarketWatch Pages as a simulation. Quantmod R library also has some basic tools.

Paper Options

09/23/2026

Igors List... Generic Architecture Docs

- Generic Architecture Docs... Are Integrative Processes.They discuss the blueprints to build a system.
- They might include new tools and processes which need to be built... which is an R&D ICB(Indiv Case Basis Process).
- There are at least 7 Generic Arch Documents which need to be written for this project which historically are 10-100 pages each at my old employers.
- There are four unique pieces of technology in design which weren't built previously (Cipher Tech, Audit Tech, API Billing Tech, And Traffic Tech)
- There are two new complex payloads to build which in Fall of 2025 took over 3 mos to test for the bikes app. I have an advantage in that I have a working backoffice model and I can compress this process.

PAPER OPTION1 – PGP – Client-Server over REST

- PGP Privacy For Financial Applications involves a combination of meeting the business requirements of PCI compliance, HIPAA Compliance, and all other known Federal Security Standards (FIPS, FISMA, NIST DOD Standards).
 - Network Encryption is a trivial problem as it turns out in REST networks.
 - However Application Encryption is required anyway due to the requirements for accountability and audit control in the Financial space.
 - Cookies, Browser Session and Local Storage, Memory, and other database and authentication issues are more problematic.
 - To prep my application for meeting the deployment standards of my own previous companies we have to meet a change control and product development standard.
 - That being said what I have termed the “Cocky Cipher” is a general encryption mechanism which is sufficient for a thesis and can manage most of the requirements to making the app we built in STATS542 ready for production. It is in the class of monosyllabic substitution ciphers in basic forms, and in its most advanced form is a complex multi-variable substitution cipher which is unbreakable by modern technology.

PAPER OPTION2 – REST AUDIT SCALING

- Building an Application with 100 tables....
 - Generates on the Order of 500 REST EP's
 - Generates Greater than 10 complex services
 - All EP's have to be checked with constrained data services, authentication and encryption.
- Challenges of Scaling Larger Endpoints

PAPER OPTION3 – TRAFFIC COLORING

- Simply the Network Reporting of Colored API Traffic using common network models.
- Moving 1000 APPS to REST would require 1000 Streams of Traffic.
- Across up to 1000 LANS in a large Enterprise
- Across a Hub-Scope Topology.

PAPER OPTION4 – USAGE BASED API BILLING

- Every API call has to be logged counted, and billed per application.
- This is Entity Framework to Billing Requirement.

Summary

- The original plan of end to end application encryption from client to REST Fabric holds.
 - We made one modification and that's to ensure Secure Transport over HTTPS independent of the rest of the architecture.
 - We have developed our own cipher which can operate in PGP mode with no keys delivered over the network, but with keys which could be decrypted by State/Federal actors with the WILL TO DO SO... or court orders.
 - We have a 5 Key System Per Stream which is mathematically impossible to break and has 1M years to run on 4GHZ single processor machine but the disk and memory requirements are so significant to run brute force calculations of more than 10B arrays that its quite literally not possible for non state actors with investments less than 10B dollars.
 - Our codes could be broken with large investments and lots of custom engineering resources. But not using word analysis or letter frequency.

The Cocky Cipher System – The Basics

- Step1 – Breaks a Payload assumed to fit inside a 1500 Byte MTU used on most routed infrastructure with extra spaces at a fixed interval which we have arbitrarily set to 5. That means every word that is more than five letters gets broken up with a space... and that makes single letter keys near impossible. (A, I no longer the only single combination)
- Step2 – Converts the Modified Payload to ASCII Values with a plus 96 shift which would puts every letter into the Extended ASCII control codes (They are no longer letters they are encoded binary and hex values).
- Step3 – Applies 1 Key on all ASCII Values PGP (25! Factorial combinations)
 - OR Applies 5 Keys on all ASCII Values which changes the shift from the 96 base.
 - OR Applies a Prime Based Mutator using Modular division to force a distribution inside the extended ASCII set.
- NOTES: The Keyless version of the Cocky Cipher can generate 5 keys using Network Time Protocol and can run in synchronous or asynch mode by simply subtracting 4 hours from the time. (4 Hour async option).

Advanced Monosyllabic Cipher Family

- Defeats Word Analysis(As it breaks words up in Pass1, and flips letter combinations)
- Defeats Letter Analysis(As it doesn't use letters)
- Can be used for coded messages in any ISO variant of ASCII supporting all known language systems.
- A Single Cipher of 255! Requires more than 200K years of time to brute force break a code assuming that Word and Letter Analysis are removed as a possibility.
- Used the explanation of CodeBreaking from Carnegie Mellon – Sr Instructor on Cryptology.
- Can be used to encrypt any communications type (FR, SONET, ATM, IP, MPLS, TOKEN RING) as a substitution cipher using ASCII codes is something every computer on earth can do... and standard ASCII hardware escalation requires no modification.

Problems... Pagination....

- A 1500 Byte Payload which injects a space in ASCII after every 5th letter makes the payload at least 20% bigger in practice or 1800 bytes... this makes the MTU usable for data communication smaller on IP circuits to about 1200 Bytes to be safe.
- 1800 Bytes after encryption would force segmentation which is a normal process for the network layer to perform... but this means that we would need to have near full control of the stack, or use a standard stack, and simply deliver encrypted text to a standard network OSI model.
- Networks are so fast.... These days... we might double packets during encryption on the worst case, but it would have to be measured.....

Options For Measurement....

- Generate a Large Block of Text - > 150 Page+ PD
 - Send across a normal network (Count the packets)
 - Encrypt the same block (Count the packets)
 - Perhaps a full dictionary of several thousand pages.
 - Understand the overhead of the cipher.
 - Generate an Estimate on Delay via fine grained C++ calcs.

Full vs. practical standard dictionaries

Dictionary	Approx. pages	Notes
Oxford English Dictionary (OED), 2nd ed.	~21,730 (20 volumes)	The comprehensive historical dictionary. Far over 10k pages.
Concise Oxford English Dictionary	~1,600–1,700	The most common “standard” single-volume Oxford dictionary. Widely used and authoritative.
Merriam-Webster’s Collegiate Dictionary	~1,500–1,800+	The standard American desk/collegiate dictionary.
Collins English Dictionary (Complete & Unabridged)	~2,000–2,300	Large single-volume option, still far under 10k.
Pocket Oxford / Concise / Learner’s editions	400–1,000	Smaller, practical versions.

Practical answer

- The **standard English dictionary** most people mean when they want a solid, complete single volume is a **Concise Oxford** or **Merriam-Webster Collegiate**. Both are typically **under 2,000 pages**.
- Anything calling itself “unabridged” or “complete” in one volume is still almost always under 3,000 pages.
- Only the multi-volume historical OED exceeds 10,000 pages.

Where to find PDFs

Many older or public-domain editions (and some more recent concise ones) are available on the Internet Archive. Modern commercial editions are copyrighted, so free full PDFs of the latest Concise Oxford or Collegiate versions are not legally freely distributable.



The Text

- The Case Studies
- The Security Project
- The Application Framework
- The REST Fabric Standards
- And Historical Training on Location, PLL, FLL is nearly complete to an RBOC standard. This is a human document which usually gets 100s of edits by the project team.
- Natasha, Linda, Igor, Bob, and everyone who touches the document would be expected to write in-line redlines in a document management system like Ariba as part of their participation in the project with emails.
- Linda would be expected to build a repository like Teams, Github, Sharepoint site with literally every document, and Gant chart, etc which is a massive job in itself.

Note....

- I had 4 professionals helping me in 542 who were well trained data architects.
- It took us three months or 12 man mos to build Gen1 and it had exactly two tables, and two pages of R code.
- My only advantage is this my 10th project in software engineering methods here at the University and I have a lot of code built and working.
- My assembly will include some prebuilt code, and some new.
- I intend to use claude code to assist with UI development, and mostly copilot and my own hand work in the backoffice for Gen4.
- To put things in perspective LUNA has had 700 Revisions since February.